

Website Vulnerability Scanner Report (Light)



Get a PRO Account to unlock the FULL capabilities of this scanner



See what the FULL scanner can do

Perform in-depth website scanning and discover high risk vulnerabilities.

Testing areas	Light scan	Full scan
Website fingerprinting	✓	✓
Version-based vulnerability detection	✓	✓
Common configuration issues	✓	✓
SQL injection	✗	✓
Cross-Site Scripting	✗	✓
Local/Remote File Inclusion	✗	✓
Remote command execution	✗	✓
Discovery of sensitive files	✗	✓

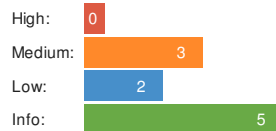
✓ <http://silasidakep.sumedangkab.go.id/>

Summary

Overall risk level:

Medium

Risk ratings:



Scan information:

Start time: 2020-10-26 02:32:21 UTC+02
Finish time: 2020-10-26 02:32:26 UTC+02
Scan duration: 5 sec
Tests performed: 10/10
Scan status: **Finished**

Findings

Insecure HTTP cookies

Cookie Name	Flags missing
ci_session	Secure

▼ Details

Risk description:

Since the **Secure** flag is not set on the cookie, the browser will send it over an unencrypted channel (plain HTTP) if such a request is made. Thus, the risk exists that an attacker will intercept the clear-text communication between the browser and the server and he will steal the cookie of the user. If this is a session cookie, the attacker could gain unauthorized access to the victim's web session.

Recommendation:

We recommend reconfiguring the web server in order to set the flag(s) **Secure** to all sensitive cookies.

More information about this issue:

<https://blog.dareboost.com/en/2016/12/secure-cookies-secure-httponly-flags/>.

Communication is not secure

<http://silasidakep.sumedangkab.go.id/>

▼ Details

Risk description:

The communication between the web browser and the server is done using the HTTP protocol, which transmits data unencrypted over the network. Thus, an attacker who manages to intercept the communication at the network level, is able to read and modify the data transmitted (including passwords, secret tokens, credit card information and other sensitive data).

Recommendation:

We recommend you to reconfigure the web server to use HTTPS - which encrypts the communication between the web browser and the server.

Directory listing is enabled

<http://silasidakep.sumedangkab.go.id/assets/plugins/animation/css/>

<http://silasidakep.sumedangkab.go.id/assets/css/>

<http://silasidakep.sumedangkab.go.id/assets/fonts/fontawesome/css/>

<http://silasidakep.sumedangkab.go.id/assets/>

<http://silasidakep.sumedangkab.go.id/assets/images/>

<http://silasidakep.sumedangkab.go.id/fav/>

<http://silasidakep.sumedangkab.go.id/assets/plugins/bootstrap/js/>

<http://silasidakep.sumedangkab.go.id/assets/js/>

▼ Details

Risk description:

An attacker can see the entire structure of files and subdirectories from the affected URL. It is often the case that sensitive files are 'hidden' among public files in that location and attackers can use this vulnerability to access them.

Recommendation:

We recommend reconfiguring the web server in order to deny directory listing. Furthermore, you should verify that there are no sensitive files at the mentioned URLs.

More information about this issue:

<http://projects.webappsec.org/w/page/13246922/Directory%20Indexing>.

Server software and technology found

Software / Version	Category
 LiteSpeed	Web Servers
 CodeIgniter	Web Frameworks
 Twitter Bootstrap	Web Frameworks
 jQuery	JavaScript Frameworks

▼ Details

Risk description:

An attacker could use this information to mount specific attacks against the identified software type and version.

Recommendation:

We recommend you to eliminate the information which permit the identification of software platform, technology, server and operating system: HTTP server headers, HTML meta information, etc.

More information about this issue:

https://owasp.org/www-project-web-security-testing-guide/stable/4-Web_Application_Security_Testing/01-Information_Gathering/02-Fingerprint_Web_Server.html.

Missing HTTP security headers

HTTP Security Header	Header Role	Status
X-Frame-Options	Protects against Clickjacking attacks	Not set
X-XSS-Protection	Mitigates Cross-Site Scripting (XSS) attacks	Not set

Details

Risk description:

Because the **X-Frame-Options** header is not sent by the server, an attacker could embed this website into an iframe of a third party website. By manipulating the display attributes of the iframe, the attacker could trick the user into performing mouse clicks in the application, thus performing activities without user's consent (ex: delete user, subscribe to newsletter, etc). This is called a Clickjacking attack and it is described in detail here:

<https://owasp.org/www-community/attacks/Clickjacking>

The **X-XSS-Protection** HTTP header instructs the browser to stop loading web pages when they detect reflected Cross-Site Scripting (XSS) attacks. Lack of this header exposes application users to XSS attacks in case the web application contains such vulnerability.

Recommendation:

We recommend you to add the **X-Frame-Options** HTTP response header to every page that you want to be protected against Clickjacking attacks.

More information about this issue:

https://cheatsheetseries.owasp.org/cheatsheets/Clickjacking_Defense_Cheat_Sheet.html

We recommend setting the **X-XSS-Protection** header to "X-XSS-Protection: 1; mode=block".

More information about this issue:

<https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-XSS-Protection>

No vulnerabilities found for server-side software

Robots.txt file not found

No security issue found regarding client access policies

No password input found (auto-complete test)

No password input found (clear-text submission test)

Scan coverage information

List of tests performed (10/10)

- ✓ Fingerprinting the server software and technology...
- ✓ Checking for vulnerabilities of server-side software...
- ✓ Analyzing the security of HTTP cookies...
- ✓ Analyzing HTTP security headers...
- ✓ Checking for secure communication...
- ✓ Checking robots.txt file...
- ✓ Checking client access policies...
- ✓ Checking for directory listing (quick scan)...
- ✓ Checking for password auto-complete (quick scan)...
- ✓ Checking for clear-text submission of passwords (quick scan)...

Scan parameters

Website URL: <http://silasidakep.sumedangkab.go.id/>
Scan type: Light
Authentication: False